# SC-900 – Eksamensnotater

Security, Compliance and Identity Fundamentals

## Oversikt og strategi

| Domene | Vekt | Kapittel |
|---|---|---|
| Konsepter: sikkerhet, compliance, identitet | 10–15 % | 1 |
| Identitetskonsepter i Microsoft Entra | 25–30 % | 2 |
| Sikkerhetsløsninger i Microsoft | **35–40 %** | 3 |
| Compliance-løsninger i Microsoft | 20–25 % | 4 |

**Strategi**

- SC-900 er fundamentals: spørsmålene er «hva gjør dette?» og «hvilken tjeneste passer her?», ikke dyp konfigurasjon.
- Domene 3 teller mest. Legg mest tid der.
- Eksamen elsker forvekslingspar (alert vs. incident, SIEM vs. XDR, DLP vs. Insider Risk). De står samlet i kapittel 5.
- På scenariospørsmål: finn nøkkelordet i oppgaven, og slå opp i jukselappen under.
- Status på nye funksjoner (Agent ID, Security Copilot-lisensiering, Azure Blueprints) kan endre seg. Sjekk Microsoft Learn.

**Tegnforklaring: Husk** = viktig å huske · **Eksamen** = typisk eksamensspørsmål · **Analogi** = huskehjelp · **Pass opp** = vanlig felle

## Jukselapp: scenario → svar

### Identitet (Entra)

| Hvis oppgaven sier… | Svar |
|---|---|
| Bekrefte HVEM du er / HVA du har tilgang til | AuthN / AuthZ |
| Regler av typen «hvis X, så Y» ved innlogging | **Conditional Access** (P1) |
| Admin-rolle bare ved behov, tidsbegrenset | **PIM** (P2) |
| Oppdage lekkede passord, umulig reise, risikable innlogginger | **Entra ID Protection** (P2) |
| Periodisk gjennomgang av hvem som har tilgang | **Access reviews** |
| Automatisk tilgang når noen begynner/bytter/slutter | **Lifecycle workflows** |
| Brukere ber om tilgangspakke med godkjenning og utløpsdato | **Entitlement management** |
| Partnere/gjester samarbeider med ansatte | **External ID: B2B** |
| Kunder logger inn i din egen app | **External ID: external tenant (CIAM)** |
| Synkronisere on-prem AD til sky | **Entra Connect** |
| Bruker nullstiller passord selv | **SSPR** |
| Tilgang til interne apper uten VPN | **Entra Private Access** |
| Sikker tilgang til internett og SaaS, webfiltrering | **Entra Internet Access** |
| Digitale legitimasjoner du eier selv | **Verified ID** |
| Identitet og styring for AI-agenter | **Entra Agent ID** |
| Azure-ressurs får identitet uten passord i koden | **Managed identity** |

### Sikkerhet

| Hvis oppgaven sier… | Svar |
|---|---|
| Koble varsler fra e-post, identitet og enhet til én hendelse | **Defender XDR** |
| SIEM + SOAR, samle logger, playbooks | **Microsoft Sentinel** |
| Phishing og skadelige vedlegg i e-post/Teams | **Defender for Office 365** |
| Beskytte PC-er/servere (EDR), isolere enhet | **Defender for Endpoint** |
| Mistenkelig aktivitet i on-prem AD, lateral movement | **Defender for Identity** |
| Oversikt og kontroll over SaaS-apper (CASB) | **Defender for Cloud Apps** |
| Sikkerhetsstatus på tvers av skyer, Secure Score (CSPM) | **Defender for Cloud** |

| | |
|---|---|
| Flom-angrep på lag 3 og 4 | **Azure DDoS Protection** |
| SQL injection, XSS, HTTP flood (lag 7) | **WAF** |
| Stateful brannmur, FQDN-filtrering, threat intelligence | **Azure Firewall** |
| Enkle tillat/blokker-regler per subnett eller NIC | **NSG** |
| RDP/SSH til VM uten offentlig IP | **Azure Bastion** |
| Lagre hemmeligheter, nøkler og sertifikater | **Key Vault** |
| Generativ AI-assistent for sikkerhetsteam | **Security Copilot** |

## Compliance (Purview m.fl.)

| Hvis oppgaven sier… | Svar |
|---|---|
| Merke og kryptere dokumenter etter sensitivitet | **Sensitivity labels** |
| Hvor lenge data beholdes / når de slettes | **Retention labels / Data Lifecycle Management** |
| Hindre deling av kredittkortnummer o.l. | **DLP** |
| Risikofylt aktivitet fra ansatte (f.eks. nedlasting før oppsigelse) | **Insider Risk Management** |
| Beskyttelse justeres automatisk etter brukerens risiko | **Adaptive Protection** |
| Samlet oversikt over datarisiko og oversharing | **DSPM** |
| Undersøke datainnbrudd med generativ AI | **Data Security Investigations** |
| Compliance score, assessments, improvement actions | **Compliance Manager** |
| Upassende kommunikasjon (trakassering, truende språk) | **Communication Compliance** |
| Finne og bevare data til juridiske saker | **eDiscovery** |
| Hvem gjorde hva, og når (aktivitetslogg) | **Audit** |
| Kartlegge datakilder og samle metadata | **Purview Data Map** |
| Finne, forstå og styre data | **Purview Unified Catalog** |
| Microsofts revisjonsrapporter og sertifiseringer | **Service Trust Portal** |

# 1. Grunnleggende konsepter (10–15 %)

## Shared responsibility model

Ansvaret deles mellom Microsoft og kunden. Jo mer mot SaaS, desto mer tar Microsoft.

| Lag | On-premises | IaaS | PaaS | SaaS |
|---|---|---|---|---|
| Fysisk + host | Kunde | Microsoft | Microsoft | Microsoft |
| OS | Kunde | Kunde | Microsoft | Microsoft |
| Apper | Kunde | Kunde | Kunde | Microsoft |
| **Data** | **Kunde** | **Kunde** | **Kunde** | **Kunde** |
| **Kontoer, tilgang, endepunkter** | **Kunde** | **Kunde** | **Kunde** | **Kunde** |

Eksempler: IaaS = Azure VM · PaaS = Azure App Service · SaaS = Microsoft 365.

> **Husk:** Uansett modell er kunden ALLTID ansvarlig for data, endepunkter, kontoer og tilgangsstyring.

## Defense in depth

Flere lag, slik at ett brutt lag ikke gir full tilgang. Utenfra og inn:

| # | Lag | Eksempler | Azure-tjeneste |
|---|---|---|---|
| 1 | Fysisk | Datasentre | (Microsoft) |
| 2 | Identitet og tilgang | IAM, MFA, RBAC | Entra ID, Conditional Access |
| 3 | Perimeter | DDoS-beskyttelse, brannmurer | DDoS Protection, Azure Firewall |
| 4 | Nettverk | Segmentering | VNet, NSG |
| 5 | Compute | Patching, endpoint protection | Bastion |
| 6 | Applikasjon | Sikker kode | WAF |
| 7 | Data | Kryptering, klassifisering | Key Vault |

## CIA-triaden

| Bokstav | Betyr | Rammes av |
|---|---|---|
| **C**onfidentiality | Kun autoriserte har tilgang | Datalekkasje |
| **I**ntegrity | Data endres ikke uautorisert | Manipulering |
| **A**vailability | Tilgjengelig når det trengs | DDoS-angrep |

## Zero Trust

«**Never trust, always verify**»: ingen implisitt tillit basert på nettverkslokasjon.

| Prinsipp | Betyr |
|---|---|
| Verify explicitly | Verifiser alltid på alle datapunkter: identitet, lokasjon, enhet, tjeneste |
| Least privilege access | Minimum nødvendig tilgang (just-in-time / just-enough) |
| Assume breach | Anta at brudd skjer. Segmenter og krypter |

**Seks pilarer:** Identiteter · Enheter · Apper · Data · Infrastruktur · Nettverk

## Kryptering og hashing

| Type | Nøkkel | Egenskap |
|---|---|---|
| Symmetrisk | Samme nøkkel til kryptering og dekryptering | Rask, men nøkkeldeling er utfordring |
| Asymmetrisk | Public/private nøkkelpar | Tregere, løser nøkkeldelingen |
| Hashing | Ingen (én-veis) | Verifiserer integritet, kan ikke reverseres |

# 2. Identitet i Microsoft Entra (25–30 %)

> Identitet er den nye sikkerhetsgrensen i en cloud-first verden, ikke nettverket.

## Entra og Entra ID

- **Microsoft Entra** = hele produktfamilien for identitet og tilgang.
- **Entra ID** = kjernen: Microsofts sky-baserte IAM-tjeneste (het tidligere Azure AD).
- Lagrer identiteter (brukere, grupper, enheter, apper), autentiserer, styrer tilgang og gir **SSO**.
- **Tenant** = organisasjonens egen instans av Entra ID.
- **AuthN** = hvem er du? · **AuthZ** = hva får du gjøre?

*Analogi: hotellresepsjonen. Har gjestelisten, sjekker ID og gir nøkkelkort.*

| Lisens | Gir blant annet |
|---|---|
| Free | Grunnleggende |
| P1 | Conditional Access |
| P2 | Identity Protection og PIM |
| ID Governance | Lifecycle workflows, entitlement management, access reviews (deler også i P2) |

**Pass opp:** Lisenskrav endrer seg. Sjekk Learn før eksamen.

## Identitetstyper

| Type | Hva | Eksempel |
|---|---|---|
| Bruker | Ansatt eller gjest | Chris i Entra |
| Enhet | PC eller telefon | Registrert / joinet PC |
| Gruppe | Samling identiteter | «Økonomi» |
| Workload | Apper og tjenester | Service principal, managed identity |
| Agent | AI-agent | Agent i Copilot Studio |

- **Service principal** = identitet for en app.
- **Managed identity** = Azure-ressurs får identitet uten at du lagrer passord i koden.
- **Enhetsidentiteter:** *registered* (privat enhet) · *joined* (organisasjonens enhet) · *hybrid joined* (on-prem + Entra).

## Hybrid identitet

```
On-prem AD DS --[Entra Connect]--> Entra ID --> Microsoft 365, Azure, skyapper
```

- Entra Connect (tidligere Azure AD Connect) synkroniserer identiteter. Brukeren har én identitet og samme innlogging overalt.
- Vanlig i norske bedrifter fordi gamle servere og apper trenger AD DS.
- **Pass opp: AD DS ≠ Entra ID.** AD DS = on-prem, Kerberos/LDAP. Entra ID = sky, OAuth/SAML.

## Eksterne identiteter (Entra External ID)

| Konfigurasjon | For hvem | Hvordan |
|---|---|---|
| **Workforce tenant: B2B collaboration** | Partnere og gjester som samarbeider med dine ansatte | Gjest legges inn som gjestebruker i din tenant |
| **External tenant (CIAM)** | Forbrukere og kunder som bruker dine egne apper | Egen, separat tenant med kundekontoer og innlogging |

**Husk:** B2B = samarbeide med andre organisasjoner. Kundeløsning = la kunder logge inn i appen din.

**Pass opp:** Azure AD B2C er ikke lenger tilgjengelig for nye kunder (fra 1. mai 2025). Nye kundeløsninger bruker External ID.

## Autentiseringsmetoder

**Passord < Passord + MFA < Passordløst** (svakest → sterkest)

| Metode | Merknad |
|---|---|
| Passord | Noe du vet. Kan gjettes, stjeles, fiskes ut |
| SMS / talesamtale | Fungerer, men svakere og ikke passordløst |

| | |
|---|---|
| Microsoft Authenticator | Godkjenn på mobilen. Passordløst |
| Windows Hello for Business | Biometri eller PIN, knyttet til enheten. Passordløst |
| FIDO2-sikkerhetsnøkkel | Fysisk nøkkel. Passordløst |

- **MFA:** noe du vet + noe du har + noe du er.
- **Phishing-resistente metoder:** Windows Hello · FIDO2 · passkey (Authenticator) · CBA (sertifikatbasert).
- **Temporary Access Pass:** midlertidig kode for å sette opp passordløse metoder.

| Forkortelse | Betyr |
|---|---|
| SSPR | Self-Service Password Reset |
| OATH | Open Authentication |
| TOTP | Time-based One-Time Password |
| OTP | One-Time Passcode |
| FIDO | Fast Identity Online |

## SSPR (Self-Service Password Reset)

Bruker glemmer passord → bekrefter identitet (Authenticator/telefon) → setter nytt passord, uten helpdesk.

- Fordel: færre henvendelser til IT.
- **Pass opp:** I hybrid kreves **password writeback** (passordet skrives tilbake til on-prem AD). Krever premium-lisens.

## Conditional Access (CA)

**Signals → Decisions → Enforcement.** Regler av typen «hvis X, så Y». Entras policy-motor for Zero Trust («verify explicitly» i praksis).

| Del | Eksempler |
|---|---|
| Signaler | Bruker/gruppe, IP-sted, enhetens tilstand, app, innloggingsrisiko |
| Krav (grant) | Krev MFA, compliant enhet, hybrid-joinet enhet, godkjent app, vilkår for bruk |
| Sesjonskontroll | Begrenset tilgang, hvor ofte du må logge inn på nytt |
| Blokker | Stopper tilgangen helt |

Eksempler: krev MFA for alle administratorer · blokker innlogging fra land dere ikke har ansatte i · krev compliant enhet for SharePoint.

> **Husk:** Krever **Entra ID P1**. **Report-only**-modus tester uten å håndheve (så du ikke låser deg ute). **Security defaults** er gratis og enklere, men mindre fleksibelt. Du bruker enten security defaults eller CA, ikke begge.

## Global Secure Access (SSE)

Sikker nettverkstilgang uten tradisjonell VPN, bygget på Zero Trust.

| Del | Hva den gjør |
|---|---|
| **Entra Internet Access** | Sikrer internett og SaaS (f.eks. Microsoft 365), webfiltrering |
| **Entra Private Access** | Tilgang til interne apper (on-prem eller sky) uten VPN, bare de appene brukeren skal ha |

*Analogi: i stedet for å åpne hele kontoret for alle (VPN) får hver person en privat korridor til akkurat de rommene de skal til.*

Kombineres med Conditional Access, så nettverkstilgang styres av identitet, enhet og risiko.

## Roller og RBAC

**Hvem (bruker/gruppe) + Rolle (hva) + Omfang/scope (hvor) = Tilgang.** Prinsipp: least privilege.

| Begrep | Betyr |
|---|---|
| Rolledefinisjon | Samling tillatelser |
| Rolletildeling | Kobler rolle til bruker/gruppe |
| Scope | Hvor rollen gjelder (hele tenanten, administrativ enhet …) |

| Entra-rolle | Kan |
|---|---|
| Global Administrator | Alt i tenanten |
| User Administrator | Administrere brukere og grupper |
| Helpdesk Administrator | Nullstille passord for ikke-privilegerte brukere |

| | |
|---|---|
| Security Reader | Lese sikkerhetsinfo, ikke endre |

- Innebygde og egendefinerte (custom) roller finnes.
- Begrens antall Global Administrators. Kombiner med PIM.

| | Styrer | Eksempel |
|---|---|---|
| **Entra-roller** | Entra-ressurser (brukere, grupper, innstillinger) | User Administrator |
| **Azure RBAC** | Azure-ressurser (VM-er, lagring) | Owner, Contributor |

## Entra ID Governance

Riktige personer, riktig tilgang, riktig tid, og tilgangen fjernes når den ikke trengs.

| Funksjon | Hva den gjør |
|---|---|
| Lifecycle workflows | Joiner / mover / leaver: automatisk tilgang når noen begynner, endring ved ny rolle, deaktivering når noen slutter |
| Entitlement management | **Access packages** (apper, grupper, nettsteder). Brukere ber om pakken, godkjenning og utløp håndteres automatisk |
| Access reviews | Jevnlig «skal de fortsatt ha denne tilgangen?» Reviewer: eier, leder eller brukeren selv. Kan fjerne tilgang automatisk |
| Terms of use | Brukere må godta vilkår før tilgang |
| PIM | Se under |

```
Ansatt begynner  -> Lifecycle workflow gir tilgang
Ber om tilgang   -> Entitlement management (access package)
Tid går          -> Access reviews rydder bort unødvendig tilgang
Ansatt slutter   -> Lifecycle workflow fjerner tilgang
```

## Privileged Identity Management (PIM)

Ingen har stående admin-rettigheter. Du aktiverer rollen ved behov, tidsbegrenset (**just-in-time**).

```
Eligible --[aktiver: MFA + begrunnelse + evt. godkjenning]--> Active --[tid går ut]--> Eligible
```

| Begrep | Betyr |
|---|---|
| Eligible | Kan aktivere rollen, men har den ikke nå |
| Active | Rollen er aktiv akkurat nå (tidsbegrenset) |

PIM gir også varsler ved aktivering, revisjonslogg, access reviews av privilegerte roller. Gjelder Entra-roller, Azure-ressursroller og gruppemedlemskap.

> **Husk:** PIM = just-in-time + least privilege. Krever Entra ID P2 eller Governance.

## Entra ID Protection

Bruker maskinlæring til å oppdage identitetsrisiko og kan svare automatisk. *Analogi: banken som stopper kortet ditt når det brukes i et annet land fem minutter etter handel hjemme.*

| Risikotype | Betyr | Typisk respons |
|---|---|---|
| **User risk** | Kontoen er sannsynligvis kompromittert | Krev passordendring eller blokker |
| **Sign-in risk** | Innloggingen er sannsynligvis ikke gjort av eieren | Krev MFA eller blokker |

- Deteksjoner: lekkede påloggingsdata, anonym IP (f.eks. Tor), umulig reise, password spray.
- Risikonivå: low / medium / high. Rapporter: risky users, risky sign-ins, risk detections.

> **Husk:** Identity Protection **oppdager**. Conditional Access **håndhever**. Krever P2.

## Entra Verified ID

Digitale, verifiserbare legitimasjoner (verifiable credentials) du eier selv og viser frem uten å dele mer enn nødvendig. Bygger på åpne standarder og desentraliserte identifikatorer (DID). *Analogi: førerkortet i lommeboka.*

```
Issuer --gir--> Holder (digital lommebok, f.eks. Authenticator) --viser--> Verifier
```

Bruk: fjern-onboarding av ansatte, bevise utdanning/arbeidsforhold, kontoopprettelse og passordnullstilling uten helpdesk.

### Entra Agent ID

AI-agenter handler selvstendig og passer verken som brukere eller vanlige apper. De får en egen identitet (en spesiell type service principal).

- Least privilege og hindres fra de mest kritiske rollene.
- Samme beskyttelser som brukere: Conditional Access og Identity Protection for agenter, livssyklus og logging.
- Motvirker **agent sprawl** (agenter uten oversikt og styring).
- Lages fra en **agent identity blueprint** (mal).
- Ingen passord eller MFA. Bruker **federated identity credentials**.

**Pass opp:** Status (preview/lansert) kan ha endret seg. Sjekk Learn.

# 3. Microsofts sikkerhetsløsninger (35–40 %)

## Defender-familien på et blikk

| Tjeneste | Beskytter | Nøkkelord |
|---|---|---|
| **Defender for Endpoint** | PC-er, servere, endepunkter | EDR, skadevare, ransomware, isolere enhet |
| **Defender for Office 365** | E-post, Teams, SharePoint, OneDrive | Phishing, ondsinnede lenker og vedlegg |
| **Defender for Identity** | On-prem Active Directory | Stjålne legitimasjoner, lateral movement |
| **Defender for Cloud Apps** | SaaS og skyapper | CASB, risikabel appbruk |
| **Defender for Cloud** | Azure, hybrid og multicloud | CSPM, CWP, Secure Score |
| **Defender XDR** | Samler alt over | Korrelasjon, incidents, én portal |

> **Husk:** Endpoint = enheter · Office 365 = e-post · Identity = kontoer/AD · Cloud Apps = SaaS.

## Microsoft Defender XDR

**XDR = Extended Detection and Response.** Kobler sammen sikkerhetsdata fra identiteter, enheter, e-post og apper for å oppdage, undersøke og håndtere avanserte angrep.

**Eksempel på et angrep i flere trinn:**

```
1. Phishing        -> Defender for Office 365 oppdager e-posten
2. Kapret konto    -> Defender for Identity ser mistenkelig identitetsaktivitet
3. Skadevare       -> Defender for Endpoint ser mistenkelig aktivitet på PC-en
4. Korrelasjon     -> Defender XDR kobler varslene til ÉN incident
5. Respons         -> Sikkerhetsteamet undersøker og utfører tiltak
```

| Begrep | Betyr |
|---|---|
| **Alert** (varsel) | Signal om mulig mistenkelig eller skadelig aktivitet |
| **Incident** | Samling relaterte varsler og bevis som representerer et mulig angrep |
| **Correlation** | Koble sammen relaterte varsler og aktiviteter |
| **Triage** | Vurdere, sortere og prioritere varsler etter alvorlighetsgrad |
| **Automated investigation and response** | Automatisk undersøkelse og støttede utbedringstiltak |
| **Remediation** | Fjerne trusselen eller redusere skaden (f.eks. isolere enhet) |

**Microsoft Defender-portalen** er ett sentralt sted for sikkerhetsteamet: Incidents & alerts · Assets · Investigation · Response actions · Reports and hunting. Hva som er tilgjengelig avhenger av lisens, konfigurasjon og rettigheter.

> **Eksamen:** Koble sammen varsler fra e-post, identitet og enheter for å oppdage et avansert angrep? → **Defender XDR**.

## Defender XDR vs. Microsoft Sentinel

| | Defender XDR | Microsoft Sentinel |
|---|---|---|
| Type | XDR: integrert trusselbeskyttelse | Skybasert **SIEM + SOAR** |
| Fokus | Angrep på tvers av Microsofts sikkerhetstjenester | Bred overvåking, logger fra mange ulike kilder |
| Gjør | Varsler → incidents, undersøkelse og respons | Samler og analyserer data, AI/analytics, automatisering |

- **SIEM** (Security Information and Event Management): samler, lagrer og analyserer logger og hendelser for å oppdage trusler.
- **SOAR** (Security Orchestration, Automation and Response): automatiserer og koordinerer respons.
- Sentinel automatiserer med **playbooks** (bygget på Azure Logic Apps).

**Pass opp:** Sentinel er svært relevant for SOC-roller. Verdt å kunne forklare godt i intervju.

## Security Copilot

Generativ AI-assistent for sikkerhet. Du skriver på vanlig språk, og den hjelper deg å undersøke trusler, oppsummere hendelser og svare raskere. *Analogi: en erfaren kollega i vaktrommet som allerede har lest loggene.*

**Bruk:** oppsummere incidents og foreslå neste steg · undersøke varsler og risikable brukere · analysere skript og filer · lage og forklare spørringer (KQL i Sentinel) · hjelpe med policyer i Entra, Intune og Purview.

> **Husk:** Copilot **erstatter ikke analytikeren**. Den sparer tid, mennesket tar beslutningen og kontrollerer svaret.

| Begrep | Betyr |
|---|---|
| Prompt | Spørsmålet eller instruksjonen |
| Session | En samtale med historikk |
| Plugin | Kobling til datakilder (Defender, Sentinel, Entra, Intune, Purview, tredjepart) |
| Promptbook | Ferdig serie prompts for en vanlig oppgave (triage, jakt, rapportering) |
| Agent | Selvstendig AI-løsning for en gjentakende oppgave |
| SCU (Security Compute Unit) | Enhet for kapasitet og forbruk |
| Standalone | Eget portalområde (securitycopilot.microsoft.com) |
| Embedded | Copilot bygd inn i Defender, Entra, Intune, Purview |
| Workspace | Der kapasitet, plugins og roller konfigureres |

**Slik behandles en prompt:**

```
Prompt -> Pre-processing (grounding) -> Orkestrering (velger plugins, henter data)
       -> LLM lager svar -> Post-processing (kontroll, formatering) -> Svar med kilder
```

- Copilot bruker data du har tilgang til. **Rettighetene dine bestemmer hva den kan hente.**
- **Grounding:** svar bygger på dine egne data, ikke bare modellens generelle kunnskap.
- Kundens data brukes **ikke** til å trene de grunnleggende modellene og blir i organisasjonens tenant.
- Svar kan være feil. Dobbeltsjekk og bruk tommel opp/ned.

**Effektiv prompt = Goal + Context + Expectations + Source**

| Element | Spørsmål | Eksempel |
|---|---|---|
| Goal | Hva vil du vite/gjøre? | Oppsummer risikable innlogginger for bruker X siste 24 timer |
| Context | Hvorfor, hvem er du? | Jeg er SOC-analytiker og undersøker mistenkelig innlogging |
| Expectations | Hvordan vil du ha svaret? | Kort punktliste med anbefalt neste steg |
| Source | Hvor skal data hentes fra? | Bruk Entra-data |

Tips: vær spesifikk · bygg på forrige svar i samme session · bruk promptbooks for gjentakende oppgaver.

**Aktivering:** (1) Azure-abonnement · (2) opprett kapasitet (abonnement, ressursgruppe, navn, region, antall SCU-er) · (3) Global Administrator eller Security Administrator fullfører onboarding · (4) velg hvem som får bruke den, slå på plugins, sett datadeling · (5) bruk standalone-portalen eller embedded. Kapasitet faktureres per time. Sjekk gjeldende lisensvilkår (E5-kunder har hatt kapasitet inkludert).

## Azure-nettverkssikkerhet: oversikt

| Tjeneste | Lag | Én setning |
|---|---|---|
| DDoS Protection | Perimeter | Stopper flom-angrep |
| Azure Firewall | Perimeter | Administrert, stateful brannmur for hele nettverket |
| WAF | Applikasjon | Beskytter webapper mot kjente angrep |
| Virtual Network | Nettverk | Isolerer og segmenterer ressurser |
| NSG | Nettverk | Filtrerer trafikk med regler på subnett og NIC |
| Bastion | Compute | Sikker RDP/SSH uten offentlig IP |
| Key Vault | Data | Trygg lagring av hemmeligheter, nøkler, sertifikater |

| Tjeneste | OSI-lag | Beskytter |
|---|---|---|
| DDoS Protection | 3 og 4 | Mot flom-angrep på nettverk og transport |
| NSG | 3 og 4 | Enkle regler per subnett eller NIC |
| Azure Firewall | 3 til 7 | All trafikk inn og ut |
| WAF | 7 | Webapper: SQL injection, XSS, HTTP floods |

## Azure DDoS Protection

DDoS overbelaster applikasjoner og servere så de blir trege eller slutter å svare. Rammer offentlige endepunkter og **availability** i CIA. *Analogi: tusenvis av falske kunder stimler inn i restauranten så ekte gjester ikke kommer inn.*

| Angrepstype | Hva det gjør | Lag |
|---|---|---|
| Volumetric | Oversvømmer nettverket så båndbredden går tom | Nettverk |
| Protocol | Tømmer serverressurser via svakheter i protokoller | 3 og 4 |
| Resource / application layer | Angriper webapplikasjoner | 7 |

- Analyserer trafikk og kaster det som ser ut som DDoS. Beskytter lag 3 og 4. **Lag 7 krever WAF i tillegg.**
- Azure har infrastrukturbeskyttelse som standard, men terskelen er høy, den gir ingen telemetri eller varsling, og den kan slippe gjennom trafikk som likevel ødelegger appen din.

| Fordel | Betyr |
|---|---|
| Always-on-overvåking | 24/7. Angrep avverges automatisk. Varsel via Azure Monitor |
| Adaptiv tuning | Lærer appens trafikkprofil over tid |
| Analyse, metrikker, varsling | Telemetri via Azure Monitor. Logger kan til Event Hubs, Monitor-logger, Storage |
| Attack analytics | Rapporter hvert 5. minutt under angrep. Logger kan til Sentinel/SIEM |

| | DDoS Network Protection | DDoS IP Protection |
|---|---|---|
| Modell | Beskytter ressurser i et virtuelt nettverk | Betaler per beskyttet IP |
| DDoS rapid response | Ja | Nei |
| Cost protection | Ja | Nei |
| WAF-rabatt | Ja | Nei |

**DDoS rapid response (DRR):** kun Network Protection. Tilgang til DRR-teamet under pågående angrep.

**Beste praksis:** kombiner DDoS (lag 3/4) og WAF (lag 7) · design for robusthet/redundans · slå på telemetri og varsling · ha en responsplan klar.

## Azure Firewall

Administrert, sky-basert nettverkssikkerhetstjeneste. *Analogi: vakten ved hovedinngangen med regelliste, som husker hvem som allerede er sluppet inn.*

| Funksjon | Betyr |
|---|---|
| Stateful | Holder styr på aktive tilkoblinger |
| Innebygd høy tilgjengelighet + availability zones | Kjører videre ved feil og høy last |
| Filtrering på nettverks- og applikasjonsnivå | IP, port, protokoll og HTTP/S via **FQDN**, inn og ut |
| NAT | SNAT og DNAT (se under) |
| Threat intelligence | Varsler/blokkerer kjente ondsinnede IP-er og domener |
| Logging | Azure Monitor, Log Analytics, Event Hubs |

| NAT | Gjør | Retning |
|---|---|---|
| **SNAT** (source) | Privat IP → offentlig Azure-IP | Ut fra VNet til internett |
| **DNAT** (destination) | Offentlig IP → privat IP | Inn fra internett til private ressurser |

| Nivå | For hvem | Kjernen |
|---|---|---|
| Basic | Små og mellomstore bedrifter | Grunnleggende. Threat intelligence kun alert. Ca. 250 Mbps |
| Standard | De fleste produksjonsmiljøer | Lag 3–7-filtrering og threat intelligence som varsler og blokkerer |
| Premium | Sensitive og regulerte miljøer | Standard + **IDPS** (over 67 000 signaturer i 50+ kategorier). Har også TLS-inspeksjon |

**IDPS** finner kjente mønstre i trafikken (bytesekvenser malware bruker).

**Azure Firewall Manager:** ett sted å styre flere brannmurer på tvers av abonnementer og regioner via brannmurpolicyer. Støtter vanlige VNet og Virtual WAN (Secure Virtual Hub).

| | Azure Firewall | NSG | WAF |
|---|---|---|---|
| Hva | Sentral, administrert, stateful | Enkle regler per subnett/NIC | Beskytter webapper |
| Filtrerer på FQDN | Ja | Nei | Nei |
| Threat intelligence | Ja | Nei | Nei |

## Web Application Firewall (WAF)

Sentralisert beskyttelse av webapper mot vanlige angrep. Du patcher en sårbarhet ett sted i stedet for i hver app. Bygger på **OWASP core rule set**.

| Angrep | Hva det gjør | Rammer |
|---|---|---|
| SQL injection | Ondsinnet SQL i inputfelt | Databasen |
| Cross-site scripting (XSS) | Skript i nettsider andre ser, stjeler sesjonstokens | Andre brukeres nettleser |
| HTTP flood | Mange HTTP-forespørsler overbelaster appen (lag 7) | Availability |
| Remote file inclusion | Lurer appen til å kjøre ekstern fil | Serveren |

| Distribusjon | Beskyttelse |
|---|---|
| **Application Gateway** | Regional WAF for apper i én region |
| Application Gateway for Containers | Containerbaserte arbeidsbelastninger |
| **Front Door** | Global WAF. Blokkerer nær kilden |
| Azure CDN | Statisk og dynamisk CDN-innhold |

> **Husk: Regional = Application Gateway. Global = Front Door.**

WAF dekker applikasjonslags-DDoS (HTTP floods), DDoS Protection dekker nettverk/transport. Sammen = defense in depth. WAF kan undersøkes med Security Copilot (Azure WAF-plugin må være på).

## Nettverkssegmentering, VNet og NSG

Segmentering = dele nettverket i mindre biter. *Analogi: HR, salg og kundeservice har hvert sitt kontor.*

- **Tre grunner:** gruppere ressurser · isolere ressurser · styringspolicyer.
- Støtter Zero Trust (**assume breach**): ett kompromittert segment kan begrenses, og lateral bevegelse hindres. Hver grense er en mulighet til å inspisere og filtrere.

```
Uten segmentering: [ web + app + db + HR ]              <- ett brudd = alt er åpent
Med segmentering:  [ web ] | [ app ] | [ db ] | [ HR ]   <- brudd stoppes ved grensen
```

**Azure Virtual Network (VNet):** byggeklossen for private nettverk i Azure. **Ingen trafikk er tillatt mellom VNet, eller inn til VNet, som standard.** Kommunikasjon må settes opp eksplisitt.

| VNet-funksjon | Betyr |
|---|---|
| Internett | Ut som standard. Inn styres via offentlige IP-er eller lastbalansere |
| Mellom Azure-ressurser | Trygt innen VNet, ikke over offentlig internett |
| On-prem | Site-to-site VPN, point-to-site VPN eller ExpressRoute |
| Filtrering | NSG og Azure Firewall |
| Ruting | Automatisk mellom subnett. Egne regler mulig |

- **Site-to-site:** hele kontornettverket til Azure · **Point-to-site:** én enhet til Azure · **ExpressRoute:** privat, dedikert forbindelse (ikke over offentlig internett).
- **Subnett:** mindre segmenter i et VNet, hvert med egne kontroller (f.eks. web i ett, database i et annet).
- **VNet peering:** kobler to VNet så de snakker som ett. Går over Azures stamnett, ikke internett. Fungerer på tvers av regioner (global VNet peering). *Analogi: privat gangbro mellom to bygninger.*

## Network Security Groups (NSG)

Filtrerer trafikk til og fra Azure-ressurser i et VNet via regler. *Analogi: dørvakt med regelliste.*

- **Én NSG per subnett og per NIC**. Samme NSG kan knyttes til mange.
- Regler evalueres etter prioritet ut fra **5-tuple:** kilde · kildeport · mål · målport · protokoll. Resultat: Allow eller Deny.

| Egenskap | Betyr |
|---|---|

| | |
|---|---|
| Name | Unikt navn |
| Priority | **Lavest tall evalueres først. Første treff vinner** |
| Source / destination | IP, IP-område, service tag eller ASG |
| Protocol | TCP, UDP, ICMP, Any |
| Direction | Inbound / outbound |
| Port range | Enkeltport eller område |
| Action | Allow / Deny |

*Service tag* = gruppe IP-prefikser fra en bestemt Azure-tjeneste.

**Standardregler** (kan ikke fjernes, men overstyres med lavere tall):

| Retning | Regel | Gjør |
|---|---|---|
| Inn | AllowVNetInBound | Tillater trafikk fra VNet til VNet (behandles først) |
| Inn | AllowAzureLoadBalancerInBound | Tillater fra lastbalanserer (nummer to) |
| Inn | DenyAllInBound | Blokkerer alt annet inn (sist) |
| Ut | AllowVNetOutBound | Tillater ut til andre ressurser i VNet |
| Ut | AllowInternetOutBound | Tillater ut til internett |
| Ut | DenyAllOutBound | Blokkerer alt annet ut |

**Application security groups (ASG):** grupper VM-er (f.eks. WebServers, AppServers, DbServers) og bruk gruppene som kilde/mål i NSG-regler i stedet for enkelt-IP-er. Nye VM-er i gruppen får reglene automatisk. *Analogi: «alle i økonomiavdelingen» i stedet for hvert navn.*

| | NSG | Azure Firewall |
|---|---|---|
| Hva | Distribuert filtrering på nettverkslaget | Fullt stateful, sentralisert brannmur som tjeneste |
| Omfang | Per subnett eller NIC | Hele organisasjonen på tvers av abonnementer og VNet |

De utfyller hverandre.

## Azure Bastion

**Problem:** eksterne utviklere trenger RDP/SSH mot VM-er. Å åpne portene mot internett gir stor angrepsflate. **Løsning:** Bastion, en fullt administrert PaaS-tjeneste i VNet-et ditt. *Analogi: alle går gjennom én sikker inngang med vakt, ikke åpen bakdør.*

- RDP/SSH fra Azure-portalen (nettleser, HTML5) **over TLS, port 443**. Passerer bedriftsbrannmurer.
- VM-ene trenger **ingen offentlig IP**, agent eller klientprogramvare.
- Gir tilgang til alle VM-er i VNet og peered VNet. Distribueres **per VNet**.
- Beskytter mot portskanning. Herdet og oppdatert av plattformen (beskytter mot zero-day).

| Nivå | Kjernen |
|---|---|
| Developer | Gratis, delt infrastruktur, dev/test. Én tilkobling om gangen |
| Basic | Dedikert, fast kapasitet, produksjon |
| Standard | Basic + skalering, delbare lenker, IP-baserte tilkoblinger, native klient, filoverføring |
| Premium | Standard + **sesjonsopptak** og **kun privat distribusjon** |

Tilkobling: nettleser (alle nivåer) · native klient (Standard+) · delbare lenker (Standard+).

## Azure Key Vault

Sky-tjeneste for trygg lagring av hemmeligheter. *Analogi: bankhvelv med logg på alle besøk.*

| Område | Betyr |
|---|---|
| Secrets management | Tokens, passord, API-nøkler, sertifikater |
| Key management | Lage og styre krypteringsnøkler |
| Certificate management | Opprette, administrere, distribuere TLS/SSL-sertifikater |

- Utviklere slipper å lagre hemmeligheter i koden. Appen henter dem ved kjøring.
- All tilgang krever autentisering (**Entra ID**) og autorisasjon (**Azure RBAC eller Key Vault access policy**). Logging av all bruk.
- Microsoft ser ikke eller henter ut dataene dine.

- Støtter **least privilege** og begrenser **blast radius** ved kompromittert legitimasjon.
- Replikeres innen region og til sekundær region.
- Integrasjoner: Azure Disk Encryption, Azure SQL / SQL Server, App Service, automatisk sertifikatfornyelse.

| Nivå | Beskyttelse | Passer for |
|---|---|---|
| Standard | Programvarebasert nøkkelbeskyttelse | De fleste |
| Premium | **HSM**-beskyttede nøkler | Strenge krav (finans, offentlig sektor) |

HSM = dedikert maskinvare som lager og lagrer nøkler manipulasjonssikkert. Nøklene forlater aldri HSM-grensen.

## Microsoft Defender for Cloud

**CNAPP** (Cloud-Native Application Protection Platform): samlet løsning for å beskytte applikasjoner gjennom hele livssyklusen, på tvers av Azure, AWS, GCP og on-prem. *Analogi: sikkerhetssjefen for hele bygget: sjekker låsene, vakter ved viktige rom, tegningene før noe bygges, og egne regler for robotene (AI).*

**Tre pilarer:** DevOps-sikkerhet · **CSPM** (styre sikkerhetsstatus) · **CWP** (beskytte arbeidsbelastninger). Pluss AI-sikkerhet.

| Begrep | Betyr |
|---|---|
| Sikkerhetspolicy | Regel som måler om en ressurs er trygt konfigurert (bygger på Azure Policy) |
| Sikkerhetsstandard | Samling policyer (initiative). Standard: **Microsoft Cloud Security Benchmark (MCSB)**. Kan legge til ISO 27001, PCI DSS |
| Anbefaling | Konkret tiltak, f.eks. «Slå på MFA» |
| **Secure Score** | Prosentscore. Flere gjennomførte anbefalinger = høyere score |
| Regulatory compliance dashboard | Hvor godt du følger valgte regelverk |

**CSPM** finner risiko som eksponerte porter og svake passord.

| | Foundational CSPM (gratis) | Defender CSPM (betalt) |
|---|---|---|
| Gir | Secure score, anbefalinger, compliance, anbefalinger for Azure DevOps | **Attack path analysis**, **cloud security explorer**, agentløs skanning, AI-sikkerhet, code-to-cloud, pull request annotations |

- **Attack path analysis:** hvordan en angriper kan komme fra inngangspunkt til verdifulle ressurser.
- **Cloud security explorer:** kart/spørringer for å finne risiko.

**CWP: Defender-planer** (betalt, slås på per abonnement under Environment settings → Defender plans)

| Plan | Beskytter |
|---|---|
| Servers | Virtuelle og fysiske servere |
| Databases / SQL | Databaser |
| Storage | Lagringskontoer |
| Key Vault | Nøkkelhvelv |
| Containers | Kubernetes og containere |
| App Service | Webapper |
| APIs | API-er |
| AI Services | Generativ AI (prompt injection, jailbreak) |

> **Husk: CSPM = forebygge** (finne svakheter). **CWP = oppdage og stoppe** angrep på selve arbeidsbelastningen.

**DevOps-sikkerhet:** støtter GitHub, Azure DevOps og GitLab. Finner IaC-feilkonfigurasjoner (f.eks. åpen lagringskonto i en mal) og eksponerte hemmeligheter i kode. *Analogi: sjekke byggetegningene før huset bygges.*

**AI-sikkerhet:** *AI SPM* (oversikt over AI BOM og sikkerhetsstatus, del av Defender CSPM) og *AI threat protection* (Defender for AI Services, oppdager trusler i sanntid).

# 4. Compliance-løsninger i Microsoft (20–25 %)

## Service Trust Portal og personvern

**Service Trust Portal (STP):** dokumentasjon om Microsofts sikkerhet, personvern og samsvar: revisjonsrapporter, sertifiseringer (f.eks. ISO 27001), hvordan Microsoft beskytter kundedata.

> **Eksamen:** STP brukes til å **kontrollere Microsofts** sikkerhet og samsvar. Det er ikke et verktøy for trusseldeteksjon.

**Microsofts seks personvernprinsipper:**

| Prinsipp | Betyr |
|---|---|
| Control | Du har kontroll over egne data |
| Transparency | Åpenhet om hvordan data samles inn og brukes |
| Security | Data beskyttes mot uautorisert tilgang |
| Strong legal protections | Juridisk beskyttelse av personopplysninger |
| No content-based targeting | Personlig innhold brukes ikke til målrettet annonsering |
| Benefits to you | Databruk skal gi brukerne fordeler |

## Microsoft Purview: portalen

Sentralt verktøy for governance, risiko og compliance (GRC).

| Område i portalen | Innhold |
|---|---|
| Core | Audit, Settings |
| Risk & Compliance | Compliance Manager, eDiscovery, Communication Compliance |
| Data Governance | Data Lifecycle Management, Data Catalog |
| Data Security | DLP, Information Protection, Insider Risk Management |

## Information Protection

**1. Dataklassifisering: finne sensitive data**

| Verktøy | Gjør | Detaljer |
|---|---|---|
| **Sensitive information types (SIT)** | Oppdager **mønstre** (kredittkort, bankkonto, personopplysninger) | Built-in · named entity (navn, adresser, medisinske begreper) · custom (nøkkelord, regex) · **EDM** (eksakte verdier fra database) · confidence level · proximity |
| **Trainable classifiers** | Klassifiserer etter **hva innholdet handler om** (AI/ML) | Pre-trained eller custom (positive og negative eksempler). Eks.: kontrakter, CV-er, fakturaer |

**2. Sensitivity labels: merke og beskytte**

- Eksempler: Public, General, Confidential, Highly Confidential. Brukes på dokumenter og e-post. Manuelt eller automatisk.
- Egenskaper: **customizable** · **clear text** (i metadata) · **persistent** (følger dokumentet) · **kun én etikett om gangen** per element.

| Kan gjøre | Betyr |
|---|---|
| Encryption | Kryptere og begrense hvem som kan åpne/endre |
| Content marking | Vannmerker, topptekst, bunntekst |
| Automatic labeling | Bruke/anbefale etikett basert på sensitiv info |
| Protect containers | Kontrollere tilgang til Teams, SharePoint, M365-grupper |
| Classification only | Klassifisere uten ekstra beskyttelse |

**Scopes:** Files & other data assets · Emails · Meetings · Groups & sites.

**Pass opp:** Etikett på et Teams/SharePoint-område beskytter **selve området**. Den merker ikke automatisk hvert dokument inni.

**Copilot:** Microsoft 365 Copilot respekterer labels og tilgangsrettigheter. Svar kan arve den mest restriktive etiketten.

**Sensitivity label policy** publiserer etiketter til brukere/grupper. Admin kan: velge hvem som ser etikettene · sette standardetikett · kreve begrunnelse ved fjerning/nedgradering · kreve at brukeren alltid velger etikett (mandatory) · lenke til hjelpesider.

**3. Explorers**

| Explorer | Viser |
|---|---|
| Content explorer | Hvilke sensitive data finnes og hvor de ligger |

| | |
|---|---|
| Activity explorer | Hva brukere gjør med data (endre etikett, kopiere til USB, skrive ut) |

> **Husk:** SIT = oppdager mønstre · Trainable classifiers = gjenkjenner tema · Sensitivity labels = merker og **beskytter** · Retention labels = **hvor lenge** data beholdes.

## Data Loss Prevention (DLP)

Oppdager, overvåker og **hindrer uønsket deling** av sensitiv informasjon (kredittkort, personnummer, bankinfo).

- **Hvor:** Exchange/Outlook, SharePoint, OneDrive, Teams, Word/Excel/PowerPoint, Windows og macOS (Endpoint DLP), enkelte tredjepartsapper.
- **Handlinger:** Warn (policy tip) · Block with override (blokker, men overstyr med begrunnelse) · Block · Quarantine · logging og varsler.
- **Lage en policy:** velg **Data → Locations → Conditions → Actions**. Ferdige maler finnes.
- **Endpoint DLP:** overvåker kopiering til USB/nettverk, utskrift, åpning i uautoriserte apper. Vises i Activity explorer.
- **Teams og AI:** kan blokkere meldinger med sensitiv info og advare mot deling med tredjeparts AI-nettsteder. Security Copilot kan oppsummere DLP-varsler (Alert Triage Agent prioriterer automatisk).

## Insider Risk Management (IRM)

Oppdager, undersøker og håndterer risikofylt aktivitet **fra personer internt**: datalekkasje, tyveri av bedriftshemmeligheter, svindel, nedlasting før oppsigelse, deling med uautoriserte AI-tjenester.

```
Policies -> Alerts -> Triage -> Investigate -> Action
```

- **Insider Risk Analytics:** kartlegger mulige risikoer *før* policyer opprettes.
- Funksjoner: policies (maler/egendefinert) · alerts · **cases** · user activity · content explorer. Personvern er innebygd som prinsipp.

## Adaptive Protection

Bruker ML og risikonivåer fra IRM til å **tilpasse beskyttelsen automatisk** etter brukerens risiko.

| Nivå | Risiko | Typiske tiltak |
|---|---|---|
| Minor | Lav | Policy tips, påminnelser |
| Moderate | Middels | Strengere advarsler, krav om begrunnelse |
| Elevated | Høy | Blokkering av deling eller apptilgang |

Nivåene oppdateres automatisk. Integrerer med **DLP** (justerer delingsregler), **Data Lifecycle Management** (kan bevare slettet innhold fra Elevated-brukere i 120 dager) og **Conditional Access** (krev vilkår, begrens apper, blokker).

> **Husk: IRM oppdager risiko. Adaptive Protection bruker risikoen til å justere beskyttelsen automatisk.**

| Typisk eksamensspørsmål | Svar |
|---|---|
| Automatisk tilpasse beskyttelse etter risiko | Adaptive Protection |
| Oppdage risikofylt intern aktivitet | Insider Risk Management |
| Hindre deling av sensitive data | DLP |
| Begrense apptilgang etter policy | Conditional Access |

## DSPM og Data Security Investigations

**DSPM (Data Security Posture Management):** samlet oversikt over datarisiko. Svarer på: *Hvilke data har vi? Hvor ligger de? Hvem har tilgang? Hvordan er de beskyttet?*

- Oppdager sensitive data og mangler i beskyttelsen. Anbefaler tiltak (labels, DLP). Kan fjerne offentlige delingslenker og redusere **oversharing**. Samler innsikt fra DLP, IRM og Information Protection.
- Dekker M365, Azure, Microsoft Fabric og tredjepart (GCP, Snowflake, Databricks).
- **Shadow data:** sensitive data utenfor kjente/administrerte plasseringer.
- Sider: Posture · Objectives · AI observability · Asset explorer · Reports.

**Data Security Investigations (DSI):** undersøker datainnbrudd og lekkasjer ved hjelp av generativ AI.

- **Vector search** (søker på mening, ikke bare nøkkelord) · **Categorization** · **Examination** (f.eks. eksponerte passord).
- Integrerer med IRM, Defender XDR, DSPM og unified audit log.
- **Soft purge** = kan gjenopprettes · **Hard purge** = permanent. Pay-as-you-go.

| Verktøy | Gjør |
|---|---|
| DSI | Undersøker data og risiko |
| DSPM | Finner datasikkerhetsrisikoer |
| | |

| | |
|---|---|
| IRM | Oppdager risikofylt intern aktivitet |
| DLP | Hindrer uønsket deling |

## Compliance Manager

Vurderer og forbedrer etterlevelse av lover og standarder på tvers av skymiljøer.

| Begrep | Betyr |
|---|---|
| **Compliance score** | Fremgang. Høyere = flere forbedringstiltak fullført. Består av *your points* og *Microsoft-managed points* |
| **Controls** | Krav fra lov/standard. *Microsoft-managed* · *Customer-managed* · *Shared* |
| **Assessments** | Samling kontroller for én standard (f.eks. ISO 27001) |
| **Regulations** | Ferdige maler for å opprette assessments |
| **Improvement actions** | Konkrete tiltak. Kan tildeles og dokumenteres |

## Communication Compliance, eDiscovery, Audit, DLM og Records

**Communication Compliance:** oppdager upassende eller regelstridig kommunikasjon (trakassering, trusler, deling av sensitiv info) i Teams, Outlook, Viva Engage, WhatsApp og AI-samtaler. Flyt: **Configure → Investigate → Remediate → Maintain**.

**eDiscovery:** finne, bevare og analysere elektronisk informasjon som bevis i juridiske saker.

| Begrep | Betyr |
|---|---|
| Case | Samler søk og data for én sak |
| Search | Finner data i Exchange, Teams, SharePoint, OneDrive |
| **Hold** | Bevarer data så de ikke slettes |
| Review set | Samler data for gjennomgang |
| Export | Eksporterer funn |
| Search and delete | Finner og sletter skadelig innhold |

Premium: **OCR** · **conversation threading** · **decryption**.

**Audit:** logger bruker- og adminaktivitet. **Unified audit log** samler logger fra M365 (Teams, Exchange, SharePoint, OneDrive, Copilot).

| | Standard | Premium |
|---|---|---|
| Retention | **180 dager** (på som standard) | Opptil 1 år (10 år med tilleggslisens) |
| Ekstra | Søk og eksport til CSV | Egne retention policies, intelligente innsikter, høyere API-kapasitet |

Søk via Purview-portalen, PowerShell (*Search-UnifiedAuditLog*) eller API.

**Data Lifecycle Management (DLM):** behold data så lenge det trengs, slett når det ikke lenger trengs.

- **Retention policy:** område- eller postkassenivå · **Retention label:** enkeltelementer.
- Tre varianter: *retain-only* · *delete-only* · *retain and then delete*. **Retention label policy** publiserer etiketter.
- Mailbox archiving · inactive mailboxes · Copilot-prompter og svar kan beholdes eller slettes via retention.

**Records Management:** viktige dokumenter som må beholdes for juridiske/regulatoriske krav.

> **Husk:** Audit = aktivitetslogger · eDiscovery = juridiske undersøkelser · DLM = oppbevaring og sletting · Records = viktige dokumenter og arkivkrav.

## Data governance: Data Map og Unified Catalog

Data governance = at data er trygge, pålitelige, av god kvalitet og brukes riktig. Beskytter data **og** gjør dem nyttige.

| | Data Map | Unified Catalog |
|---|---|---|
| Gjør | **Skanner**, oppdager og samler **metadata**. Klassifiserer sensitive data | **Organiserer, finner og styrer** data |
| Detaljer | Metadata-typer: technical, business, semantic, operational. Hybrid og multicloud. Gir ikke tilgang til selve dataene | Governance domains · data products · glossary terms · critical data elements (CDE) · OKRs · access policies · søk (Copilot støtter naturlig språk) · health management · data quality |

- Begreper: federated governance · data access · data curation · data discovery · data health · data understanding.

- **Roller:** data consumer (bruker) · data owner (tilgang og kvalitet) · data steward (kvalitet og begreper) · central data office (regler og oppfølging).

> **Husk: Data Map = samler metadata. Unified Catalog = gjør metadata nyttige og søkbare.**

## Regelverk og ressursstyring

- **GDPR:** EUs personvernforordning. **Data Subject Requests (DSR):** enkeltpersoners forespørsler om egne data. Purview hjelper med å dokumentere etterlevelse.

| Azure-verktøy | Gjør |
|---|---|
| **Azure Policy** | Håndhever regler på tvers av ressurser (f.eks. alle VM-er må ha kryptering) |
| **Resource Locks** | Hindrer utilsiktet sletting/endring |
| Azure Blueprints | Pakker policyer, roller og maler for rask, kompatibel utrulling. **Pass opp:** Microsoft har varslet utfasing. Sjekk Learn |

| Sensitivity labels | Retention labels |
|---|---|
| Klassifiserer og **beskytter** (kryptering, vannmerke, tilgang) | Styrer **hvor lenge** data beholdes/slettes |
| Bruker eller automatisk | Uavhengig av sensitivitet |

# 5. Forvekslingspar (eksamensfeller)

| Par | Forskjellen |
|---|---|
| AuthN vs. AuthZ | Hvem du er vs. hva du får gjøre |
| Entra vs. Entra ID | Produktfamilien vs. kjernetjenesten |
| AD DS vs. Entra ID | On-prem (Kerberos/LDAP) vs. sky (OAuth/SAML) |
| B2B vs. CIAM | Samarbeide med partnere vs. kunder i din app |
| Entra-roller vs. Azure RBAC | Styrer Entra-ressurser vs. Azure-ressurser |
| PIM vs. Access reviews | JIT-aktivering av admin-roller vs. periodisk gjennomgang |
| Identity Protection vs. Conditional Access | Oppdager risiko vs. håndhever svaret |
| Alert vs. incident | Ett signal vs. samling relaterte varsler |
| XDR vs. SIEM/SOAR | Korrelerer Microsofts Defender-signaler vs. samler logger bredt og automatiserer |
| CSPM vs. CWP | Forebygge (svakheter) vs. oppdage/stoppe angrep |
| DDoS Protection vs. WAF | Lag 3–4 vs. lag 7 |
| NSG vs. Azure Firewall | Enkle regler per subnett/NIC vs. sentral, stateful, FQDN, threat intelligence |
| Application Gateway vs. Front Door | Regional vs. global WAF |
| SNAT vs. DNAT | Ut (privat → offentlig) vs. inn (offentlig → privat) |
| Site-to-site vs. point-to-site | Hele nettverket vs. én enhet |
| SIT vs. trainable classifier | Mønster vs. tema |
| Sensitivity vs. retention labels | Beskytte vs. beholde |
| DLP vs. IRM | Hindrer deling vs. oppdager risikofylt intern atferd |
| IRM vs. Adaptive Protection | Oppdager vs. justerer beskyttelse automatisk |
| Content vs. Activity explorer | Hvor data ligger vs. hva brukere gjør |
| Data Map vs. Unified Catalog | Samler metadata vs. gjør dem søkbare og styrt |
| Audit Standard vs. Premium | 180 dager vs. opptil 1 år (10 år med tillegg) |

# 6. Selvtest

Dekk til høyre kolonne og svar høyt.

| Spørsmål | Svar |
|---|---|
| Hva står XDR for, og hva er formålet med Defender XDR? | Extended Detection and Response. Kobler data og varsler for å oppdage, undersøke og håndtere avanserte angrep |
| Hvilken Defender-tjeneste stopper phishing-e-post? | Defender for Office 365 |
| Hva er forskjellen på alert og incident? | Alert = ett signal. Incident = samling relaterte varsler/bevis |
| Hva betyr triage? | Vurdere og prioritere varsler etter alvorlighetsgrad |
| Hva står SIEM og SOAR for? | Security Information and Event Management · Security Orchestration, Automation and Response |
| Hva er de tre Zero Trust-prinsippene? | Verify explicitly · least privilege · assume breach |
| Hva er forskjellen på eligible og active i PIM? | Kan aktivere vs. aktiv nå (tidsbegrenset) |
| Hvilken lisens trengs for Conditional Access? | Entra ID P1 |
| Hva må til for SSPR i hybrid? | Password writeback |
| Hvilket lag dekker DDoS Protection? Og WAF? | Lag 3–4 · lag 7 |
| Hva er standardregelen for innkommende trafikk til en NSG? | Tillat fra VNet og lastbalanserer, blokker alt annet |
| Hvilken NSG-regel evalueres først? | Den med lavest prioritetstall |
| Hva gjør Bastion, og hvorfor trengs ingen offentlig IP? | RDP/SSH over TLS fra portalen. Bastion kobler til VM-ens private IP |
| Hva er forskjellen på Key Vault Standard og Premium? | Programvare- vs. HSM-beskyttede nøkler |
| Hva finner attack path analysis, og hvilken plan trengs? | Angriperens vei til verdifulle ressurser. Defender CSPM (betalt) |
| Hvor mange sensitivity labels kan ett dokument ha? | Én |
| Hvilke DLP-handlinger finnes? | Warn · block with override · block · quarantine |
| Hva er Elevated i Adaptive Protection? | Høyeste risikonivå, strengeste tiltak |
| Hvor lenge beholder Audit Standard logger? | 180 dager |
| Hva brukes Service Trust Portal til? | Se Microsofts revisjonsrapporter, sertifiseringer og compliance-dokumentasjon |